



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Mirage Kitten Aviation and FinTech Developer Targeting with NodeRabbit and PollCat

Threat Report

Classification	TLP:CLEAR
Published	2026-09-03
Version	1.0
Author	Lost Boys Cyber
Report Type	Threat Report

TLP:CLEAR | Lost Boys Cyber | Mirage Kitten Aviation and FinTech Developer Targeting with NodeRabbit and PollCat - Threat Report

Published: 2026-09-03 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirements
3. Source Review & Confidence
4. Threat Activity Overview
5. Affected Sectors and Exposure
6. Aviation and Aerospace Sector Impact
7. Tactics, Techniques, and Procedures
8. Infrastructure and Indicators
9. Detection Engineering
 - 9.1. Detection Summary
 - 9.2. Sigma / Detection Content
 - 9.3. Hunt Query
10. Threat Hunting
 - 10.1. Hunt Hypothesis
 - 10.2. Hunt Query
11. Risk Assessment
12. Recommended Actions
13. References

Mirage Kitten Aviation and FinTech Developer Targeting with NodeRabbit and PollCat

1. Executive Summary

This report was selected for the 2026-09-03 UTC Lost Boys Cyber daily coverage set because it presents actionable defender relevance, current source coverage, and clear opportunities for detection or threat hunting. The activity or trend should be reviewed by SOC, vulnerability management, identity, and sector-risk owners.

Primary exposure: Aviation, aerospace, and financial technology organizations across the Middle East and Africa; developer and engineering staff are the primary exposure path. The report does not assert victim compromise beyond public source claims; it converts available reporting into defensive priorities, hunt hypotheses, and operational controls.

2. Intelligence Requirements

Question	Current Answer	Confidence
What happened?	Public reporting describes Mirage Kitten Aviation and FinTech Developer Targeting with NodeRabbit and PollCat.	High
Who should care?	Aviation, aerospace, and financial technology organizations across the Middle East and Africa; developer and engineering staff are the primary exposure path.	High
What can defenders do today?	Review exposure, run the included hunts, and validate mitigations against recent telemetry.	High

3. Source Review & Confidence

Source	Contribution	Confidence
Securelist via IT Security News	Kaspersky/Securelist-indexed reporting of NodeRabbit and PollCat malware in Mirage Kitten operations.	Medium-High
The Record	Corroborates Iranian espionage targeting of aviation, aerospace and fintech developers.	Medium-High
Security Affairs	Reports fake LinkedIn/coding-test lure tradecraft and new malware set.	Medium-High
GBHackers	Provides technical context including Azure-hosted C2 and encrypted JSON request behavior.	Medium-High

Source depth was sufficient for a defensive threat report. Hard IOCs were not consistently available in collected public sources, so this report emphasizes TTP and telemetry-based analytics.

4. Threat Activity Overview

Reporting points to Mirage Kitten / UNC1549 / Smoke Sandstorm / Nimbus Manticore activity/trends involving Phishing and job-test social engineering, User execution of developer challenge content, JavaScript/Node.js malware execution, Cloud-hosted C2 over encrypted JSON. For defenders, the highest-value action is to convert these observations into exposure review and telemetry hunts rather than waiting for environment-specific IOCs.

5. Affected Sectors and Exposure

Exposure Area	Why It Matters	Recommended Review
Identity and remote access	Valid accounts reduce attacker friction and bypass many perimeter controls.	Review MFA fatigue, impossible travel, help-desk reset and risky sign-in patterns.
Internet-facing applications	Public services remain common initial access and implant placement points.	Confirm patch status and inspect web logs for unusual POST/URI/user-agent patterns.
Endpoint and developer workstations	Lures and developer workflows can execute scripts or malware locally.	Monitor Node.js, PowerShell, shell and archive execution from user-writable paths.
Third-party and shared platforms	Aviation and other operators depend on vendors and SaaS that can become blast-radius multipliers.	Review vendor access, SSO integrations, and contingency procedures.

6. Aviation and Aerospace Sector Impact

Sector Segment	Operational Relevance	Likely Exposure Path	Defender Action
Airlines / airports	Disruption can affect passenger processing, baggage, dispatch, crew or maintenance workflows.	Identity compromise, shared service provider access, exposed web apps, or third-party SaaS.	Prioritize privileged identity review, vendor access controls, and operational continuity playbooks.
Aerospace / defense manufacturing	Theft or disruption can affect engineering, MRO, and sensitive supply-chain workflows.	Developer targeting, remote access, code repositories, managed-service access.	Segment engineering networks and review repository, CI/CD and remote-access logs.
Satellite / connectivity dependencies	Service disruption can affect communications, tracking, telemetry or downstream aviation data.	Identity compromise at providers, ground-station exposure, support-system compromise.	Validate vendor incident contacts and alternate operating procedures.

7. Tactics, Techniques, and Procedures

Tactic / Phase	Observed Technique	Evidence
Initial Access	T1566 Phishing	Phishing and job-test social engineering described in source reporting or analyst synthesis.
Execution/C2/Impact	T1059 Command and Scripting Interpreter	User execution of developer challenge content described in source reporting or analyst synthesis.
Execution/C2/Impact	T1071 Application Layer Protocol	JavaScript/Node.js malware execution described in source reporting or analyst synthesis.
Execution/C2/Impact	T1078 Valid Accounts	Cloud-hosted C2 over encrypted JSON described in source reporting or analyst synthesis.

8. Infrastructure and Indicators

Indicator / Infrastructure	Type	Operational Use
No normalized hard IOCs available in collected public source set	Source limitation	Hunt on behaviors and telemetry patterns instead of relying on blocklists.
Cloud-hosted C2 / direct-IP / SaaS identity patterns where applicable	Behavioral infrastructure	Review egress, proxy, Entra and EDR logs for suspicious flows.

9. Detection Engineering

This section includes deployable starting points. Tune filters to local baselines before production alerting.

9.1. Detection Summary

Signal	Telemetry Source	Analytic Goal
Suspicious scripting or developer-runtime execution from downloads/temp paths	EDR process creation	Catch lure-driven malware execution.
Direct-to-IP or rare ASN egress from user endpoints	Network/EDR	Catch DNS-bypass C2 and unusual beaconing.
Risky cloud identity sign-ins and MFA reset patterns	Entra/IdP logs	Catch credential-theft and social-engineering outcomes.

9.2. Sigma / Detection Content

```

title: Mirage Kitten Aviation and FinTech Developer Targeting with NodeRabbit and PollCat - Suspicious Activity Heuristic
id: auto-generated-mirage-kitten-aviation-and-fintech-developer-tar
status: experimental
description: Detects process or network command-line clues that should be reviewed in context for this report.
logsource:
  product: windows
  category: process_creation
detection:
  selection_cmd:
    CommandLine|contains:
      - 'Mirage Kitten'
      - 'Phishing and job-test social engineering'
      - 'User execution of developer challenge content'
      - 'JavaScript'
  condition: selection_cmd
falsepositives:
  - Administrative validation, vulnerability scanning, or approved red-team testing.
level: medium

```

9.3. Hunt Query

```

// Hunt for suspicious activity related to Mirage Kitten Aviation and FinTech Developer Targeting with NodeRabbit and PollCat
DeviceNetworkEvents
| where Timestamp > ago(14d)
| where RemoteUrl has_any ('Mirage Kitten', 'Phishing and job-test social engineering', 'User execution of developer challenge content', 'JavaScript', 'Cloud-hosted C2 over encrypted JSON') or InitiatingProcessCommandLine has_any ('Mirage Kitten', 'Phishing and job-test social engineering', 'User execution of developer challenge content', 'JavaScript', 'Cloud-hosted C2 over encrypted JSON')
| project Timestamp, DeviceName, InitiatingProcessAccountName, InitiatingProcessFileName, RemoteUrl, RemoteIP, InitiatingProcessCommandLine

```

10. Threat Hunting

10.1. Hunt Hypothesis

If this activity is present, telemetry should show a cluster of suspicious user execution, rare network egress, risky sign-in behavior, or web-server process anomalies connected by account, device, or time window.

10.2. Hunt Query

```
let lookback = 14d;
let suspect_terms = dynamic(['Mirage Kitten', 'Phishing and job-test social engineering', 'User
execution of developer challenge content', 'JavaScript', 'Cloud-hosted C2 over encrypted JSON']);
DeviceProcessEvents
| where Timestamp > ago(lookback)
| where ProcessCommandLine has_any (suspect_terms) or FolderPath has_any ("\\Downloads\\", "\\Temp\\",
"/tmp/", "/var/www/")
| summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), Cmds=makeset(ProcessCommandLine, 10) by
DeviceName, InitiatingProcessAccountName, FileName
| order by LastSeen desc
```

11. Risk Assessment

Dimension	Rating	Rationale
Likelihood	Medium	Current public reporting and common exposure paths make opportunistic contact plausible.
Impact	High	Credential theft, malware execution, or shared-platform compromise can produce operational disruption.
Detection Maturity Need	High	Behavioral analytics are required because hard IOCs may be absent or short-lived.

12. Recommended Actions

Priority	Owner	Action
Critical	SOC	Run the included KQL hunts and review hits with identity and endpoint context.
High	Vulnerability / Platform	Confirm public-service patching, exposed admin interfaces, and third-party access restrictions.
High	Identity	Enforce phishing-resistant MFA for privileged and developer accounts; review risky sign-ins.
Medium	Resilience	Update incident runbooks for third-party/shared-platform disruption.

13. References

- [1] Securelist via IT Security News: <https://www.itsecuritynews.info/mirage-kitten-targeting-aviation-and-fintech-sectors-across-the-middle-east-and-africa-with-a-new-malware-set/>
- [2] The Record: <https://therecord.media/iranian-cyber-spies-target-aviation-fintech-new-malware>

- [3] Security Affairs: <https://securityaffairs.com/198289/apt/iran-linked-apt-mirage-kitten-uses-fake-job-tests-to-spread-malware.html>
- [4] GBHackers: <https://gbhackers.com/mirage-kitten-campaign/>